Information Sheet - Data Protection Act 2018 and General Data Protection Regulation (GDPR)

The rapid spread of digital technology has made it easier to collect, store and share data than ever before. This includes potentially sensitive personal data and information - for example, the names and addresses of customers or appraisal records of team members.

In the UK, the key statute relating to personal data and privacy is the Data Protection Act 2018. This Act incorporates the requirements set out by the European Union's General Data Protection Regulation, or GDPR. The GDPR sets out principles that organisations need to honour in order to comply with privacy law. These specify how a company should handle personal data so that it remains secure.

Principles of Personal Data Handling

The GDPR identifies seven key principles that guide how organisations collect, use and store personal data.

- **Lawfulness, fairness and transparency**
  This principle directs organisations to communicate in an open, honest and clear manner about the collection of personal data. For instance, a website must alert you to the data it collects on you when you use it, and in most cases you must provide permission for this to take place.

- **Purpose limitation**
  The purpose for data collection needs to be documented as part of the organisation's internal records before it takes place. Consent is needed to use the data for a different purpose, unless there is another legal reason to justify this. So if a company decides to use customer data for political marketing purposes, when this wasn't the original agreed purpose, it will be breaking the law.

- **Data minimisation**
  Organisations are limited to holding only that personal data which is relevant to a predetermined, lawful, and specified purpose - and nothing beyond this. Companies can't decide to track as much personal data as they wish - only what they need for this purpose.

- **Accuracy**
  Data collected should be accurate and not misleading in any way. But there is also a requirement to think about ways that personal data could become inaccurate. For example, if an employee is dismissed for misconduct, but is subsequently exonerated, their personnel records must be updated to reflect this. Organisations need to take 'reasonable steps' to update data so that it is accurate.

- **Storage limitation**
  This concerns how long organisations can retain personal data. This will vary, but needs to be justified by your purpose for using the data in the first place. Data that is no longer relevant or required should be erased, unless it needs to be held for legal reasons, or it's in the public interest - for example, if it's historically important.

© Mindful Education Ltd

- **Integrity and confidentiality**
  Organisations must ensure they take the necessary steps to keep data confidential, intact and secure. This also applies to retrieving data - companies must have measures in place to restore access to data, where this has been lost. Security can't be assumed; organisations must carry out risk assessments to determine if data storage arrangements, and related policies are fit for purpose. The GDPR also sets out standards for detecting and handling data breaches, including those that involve actual loss or theft of data.

- **Accountability**
  This covers all of the principles already examined. This is because organisations must demonstrate they've taken responsibility for compliance with all GDPR principles, and have kept records to show this.

Individual Rights

The law also gives individuals certain rights regarding the collection, use and storage of their data. These mirror the principles above. Companies must honour these rights in the way they process data, and respond to individual requests for access.

Three examples of the rights of individuals are illustrated below:

- **The right to be informed**
  Individuals have the right to be informed about the collection, use and storage of their personal data. As we saw previously, organisations need to let people know - clearly and simply - why they are collecting the data, how long they intend to keep it, and who it will be shared with. This information needs to be communicated at the point of data collection[1].

- **The right of access**
  Individuals have the right to access the personal data held on them, and understand how an organisation is using it. They are not usually required to pay a fee to do so. They can request access verbally or in writing, and the company must respond within one month.

- **The right to erasure**
  Also known as the 'right to be forgotten', where the data no longer serves a legitimate purpose, the individual can ask that it be removed. If the data has been shared with other organisations - such as search engines - these third parties need to be notified too.

Fortunately, you don't need extensive knowledge of them - just enough to help you understand the aim of data protection law. This will help you to spot potential issues when they arise, even if you need to check the legal details later.

Further information on Data Protection Act 2018 and GDPR can be found by visiting the website of the Information Commissioner's Office - https://ico.org.uk/

[1] Information Commissioner's Office (2019) *Guide to the GDPR* available at https://ico.org.uk/for-organisations/guide-to-data-protection/guide-to-the-general-data-protection-regulation-gdpr/individual-rights/right-to-be-informed/

© Mindful Education Ltd